

Unit 6: Digital Signatures

Outline

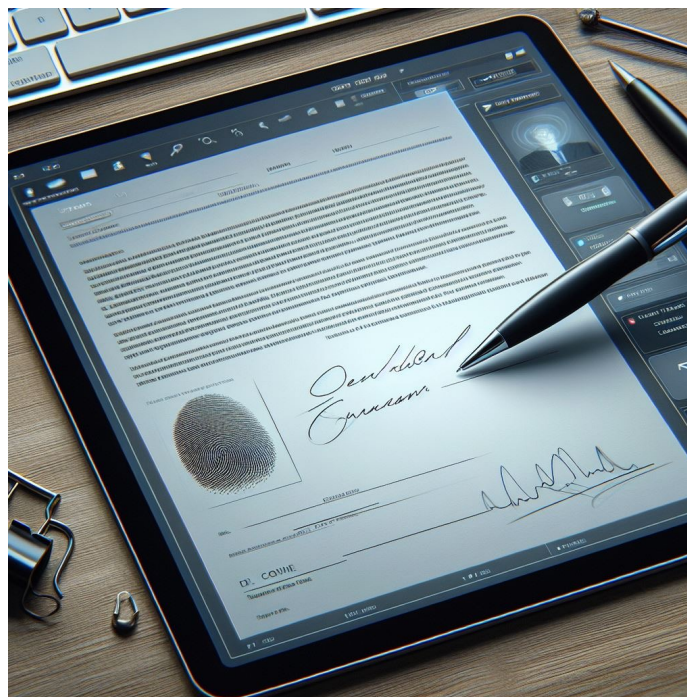
1. What is a digital Signature?
2. RSA Digital Signatures
3. DSA Digital Signatures
4. Real-world Applications

What we have seen

- Key agreement protocols
 - Diffie-Hellman and DH in Elliptic Curves
 - Allow us to agree on a key without a secure channel
- Asymmetric Encryption
 - Allows us to send messages without a previous key agreement
 - We can also use it to agree on a symmetric encryption key with another party
- Hash functions
 - They allow us to verify the integrity of a message

What is a digital signature?

Digital and Electronic Signatures



En Madrid, a 23 de febrero de 2024

El/La Presidente/a del Tribunal
Firmado por BLASCO ALIS JORGE -
***8578** el día 23/02/2024 con
un certificado emitido por AC
FNMT Usuarios

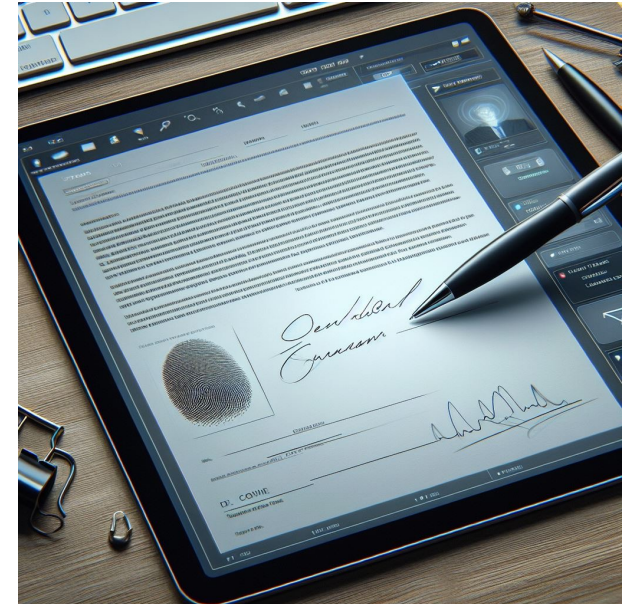
Jorge Blasco Alís

Digital Signature vs Electronic Signature

- Digital Signature
 - Refers to technical aspects of the signatures
 - Algorithms
 - Standards, etc.
- Electronic Signature
 - Refers to legal aspects of the signatures
 - Legislation
 - Requirements, etc.
 - It is established at European level with the eIDAS regulation, relating to electronic identification and trust services in electronic transactions in the internal market

Simple Electronic Signature

- Definition
 - Data in electronic form attached to or logically associated with other electronic data used by the signatory for signature
- It allows the signatory to be digitally identified with their data
- Example:
 - Scanned Signature
- Very low security



Advanced Electronic Signature

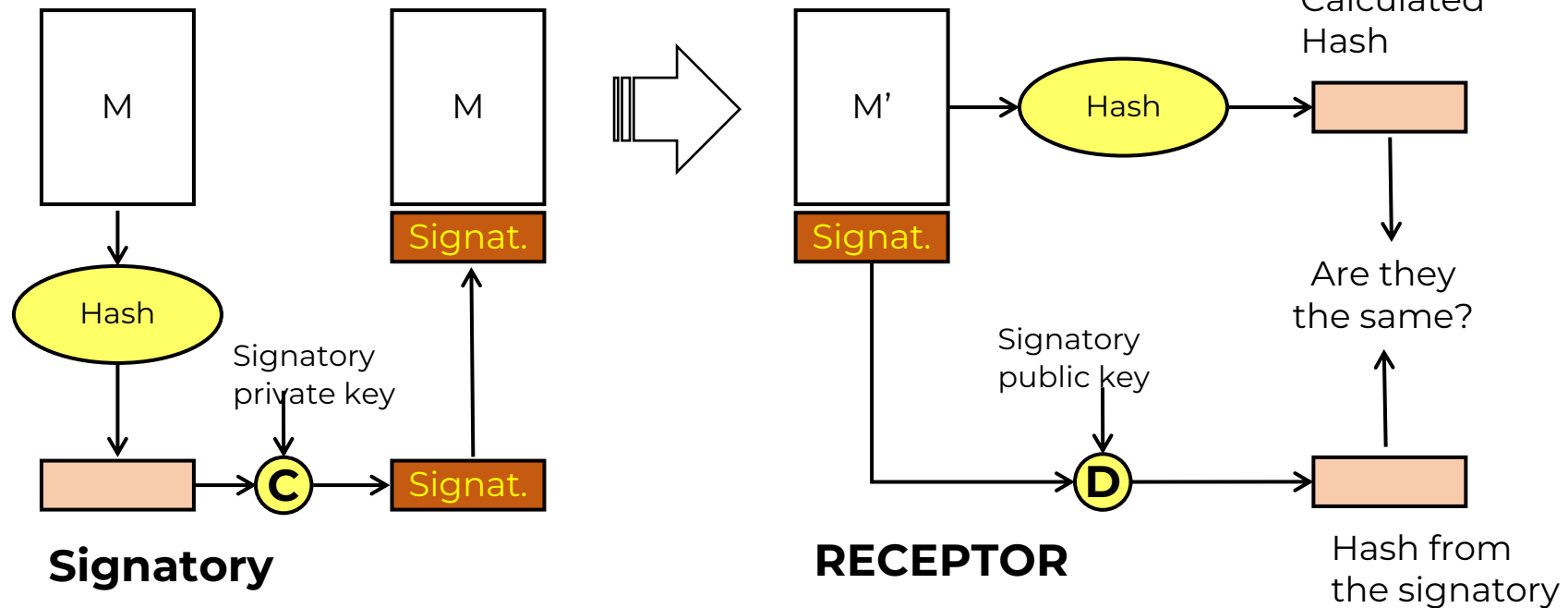
- An electronic signature that fulfils the following criteria
 - The signatory can be uniquely identified and linked to the signature
 - The signatory must have sole control of the signature creation data (typically a private key) that was used to create the electronic signature
 - The signature must be capable of identifying if its accompanying data has been tampered with after the message was signed
 - In the event that the accompanying data has been changed, the signature must be invalidated
- Examples
 - FNMT Certificates
 - App certificates

Qualified Electronic Signature

- Same as an Advanced Electronic Signature but created with a qualified signature device
- From a legal point of view, it is equivalent to a handwritten signature
- Example
 - Spanish ID Card

General Scheme for Digital Signatures

- The message is sent along with the hash encrypted with the sender's private key
- The receiver decrypts the encrypted hash with the sender's public key and calculates the hash of the message
 - If they match, the signature is valid
 - If they don't match?

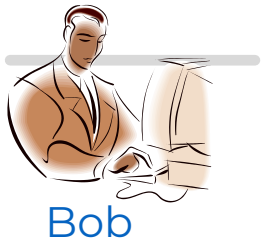


RSA Digital Signatures

RSA Digital Signature

- Bob wants to use RSA to sign a message M and send it to Alice
 1. Bob calculates the hash of the message M : $h(M)$
 2. Bob encrypts the hash of the message with his private key:
$$r = h(M)^{d_{Bob}} \bmod n_{Bob}$$
 3. Bob sends Alice the signed message: $\{M, r\}$
 4. Alice receives $\{M', r\}$ and performs the following operations
 1. Calculates $h(M')$
 2. Decrypts r with Bob's public key: $r^{e_{Bob}} \bmod n_{Bob}$
 5. If $h(M') = r^{e_{Bob}} \bmod n_{Bob}$ Alicia accepts the signature

Example



$e_B = 35$
 $n_B = 65.669$
 $d_B = 53.771$

Message M to sign:
*Final document related to
 the accepted contract.
 Bob.*



- We simplify and assume a 16-bit hash
- Bob calculates the hash: $h(M) = 0xF3A9 = 62.377$
- Bob calculates: $r = h(M)^{d_B} \bmod n_B = 62.377^{53.771} \bmod 65.669 = 24.622$
- Bob sends Alice the pair $\{M, r\} = \{M, 24.622\}$
- Alicia performs two operations
 - Decrypt the signature: $r^{e_B} \bmod n_B = 24.622^{35} \bmod 65.669 = 62.377$
 - Calculate the destination hash of the received message $h(M')$ and check if it is the same as the broadcast message

In practice, hash functions are about a few hundred bits and the current RSA cipher body is 2,048 bits

DSA Digital Signature

DSA and DSS

- In 1991 NIST proposed DSA, the Digital Signature Algorithm
 - A variant of Elgamal and Schnorr's algorithms.
- In 1994 it was established as a standard and named DSS, Digital Signature Standard

Original Public Parameters of the DSA Signature:

- A prime number p ($512 \text{ bits} < p < 1024 \text{ bits}$) [today 2.048 o 3.072 bits]
- A prime number q (160 bits) divider of $p-1$ [with SHA-1, today SHA-256]
- A generator α of order q from group p , calculated as $\alpha = g^{(p-1)/q} \bmod p$, And that it should be different than 1. It's common to use $g = 2$

Choice of parameters:

- Compute the signatory public key $y = \alpha^x \bmod p$
- Where x is the signatory private key
- Make the parameters public: q, p, α, y

Generating a DSA Signature from Alice

- Choice of parameters
 - Alice's Public Values:
 - Primes p_A , q_A and the generator α_A
 - The value to be signed $1 \leq h(M) \leq q_A$
 - Signature Secret Key
 - A random number a such that $(1 \leq a \leq q_A)$
 - Signature Public Key
 - $y_A = \alpha_A^a \bmod p_A$
- For each signature, Alice will choose a secret and random k such that $1 \leq k \leq q_A$

Generating a DSA Signature from Alice

- Signing Process
- Calculate
 - $r = (\alpha_A^k \bmod p_A) \bmod q_A$
If $r = 0$, Alice will need to choose a different value of k and calculate r again
 - $s = [(h(M) + a*r) * \text{inv}(k, q_A)] \bmod q_A$
If $s = 0$, Alice will need to choose a different value of k and calculate r and s again
- Alice's digital signature on $h(M)$ is the pair (r, s)

Notice that the r and s values sent as a signature are now reduced to the body q_A 160 bits if we use SHA-1 or 256 bits if we use SHA-2.

Checking Alice's DSA Signature

- Bob Receives the Pair (r, s) and calculates
 - $w = \text{inv}(s, q_A)$
 - $u = h(M) * w \bmod q_A$ $h(M)$ from received message
 - $v = r * w \bmod q_A$
- And checks the following equation:
 - $(\alpha_A^u y_A^v \bmod p_A) \bmod q_A = r$
- If the above is true, the receiver accepts the DSA signature as valid.

Note that the signature check is done on r , a value that does not involve the value of the message M or $h(M)$ and that, in addition, the signature is now done on values of the body q , which are much smaller than p .

Example of an Alice's DSA signature

- Alice's Public Values: $p_A = 223$, $q_A = 37$, $\alpha_A = 17$
Checks over public values p_A , q_A and α_A :
 $p_A = 223$ is prime and $(p_A - 1) = 222 = 2 * 3 * 37$
If $g = 19$, $g^{(p-1)/q} \bmod p = 19(222)/32 \bmod 223 = 17 \neq 1$, then $\alpha = 17$
- Alice's Secret Key $a = 25$
- Alice's Public Key $y_A = \alpha_A^a \bmod p_A = 17^{25} \bmod 223 = 30$
- Alice will sign the value $h(M) = 30$ ($1 \leq h(M) \leq q_A$)
- To sign, she picks $k = 12$ ($1 \leq k \leq q_A$)
- Then it will calculate:
 - $r = (\alpha_A^k \bmod p_A) \bmod q_A$
 $r = (17^{12} \bmod 223) \bmod 37 = 171 \bmod 37 = 23$
 - $s = [(h(M) + a*r) * \text{inv}(k, q_A)] \bmod q_A$
 $s = (30 + 25 * 23) * \text{inv}(12, 37) \bmod 37 = 605 * 34 \bmod 37 = 35$
- Alice's digital signature on $h(M) = 30$ will be the pair $(r, s) = (23, 35)$

Checking the signature

- Bob receives the Pair $(r, s) = (23, 35)$
- Alice's Public Values: $p_A = 223, q_A = 37, \alpha_A = 17, y_A = 30$
- Bob calculates:
 - $w = \text{inv}(s, q_A) = \text{inv}(35, 37) = 18$
 - $u = h(M) * w \bmod q_A = 30 * 18 \bmod 37 = 22$
 - $v = r * w \bmod q_A = 23 * 18 \bmod 37 = 7$
- And check that the following equality :
 - $(\alpha_A^u * y_A^v \bmod p_A) \bmod q_A = (17^{22} * 30^7 \bmod 223) \bmod 37 = 171 \bmod 37 = 23 = r$
- We get the same value of r, 23, so Bob accepts Alice's DSA signature as valid

Security in DSA and ECDSA signatures

- The constant k must always be a random and different value.
- Repeating that value in two or more signatures would allow an attacker to find the subject's private key by performing simple mathematical operations with the signature's public data.
- In December 2010, the fail0verflow group acknowledged discovering the private key used by Sony to sign the PS3 console's software.
- Sony didn't use different random k values for each signature
- PS3 hacked through poor cryptography implementation
 - <https://arstechnica.com/gaming/2010/12/ps3-hacked-through-poor-implementation-of-cryptography/>
- Breaking ECDSA (Elliptic Curve Cryptography)
 - <https://www.youtube.com/watch?v=-UcCMjQab4w>
- PS3 Private Key discovered fail0verflow
 - https://www.youtube.com/watch?v=LP1t_pzxKyE

Real-world applications

Applications

- Online Browsing
- Electronic ID card
 - Authentication
 - Document Signing
- App & Game Signing (Mobile, Desktop, Console)
- ...

Summary

- The digital signature makes it possible to ensure that
 - A message/document/file has not been modified
 - The message has been "signed" by the private key holder
- The legal validity of a signature depends on a set of requirements
- As a general rule, digital signatures require private key encryption of the hash of the message to be signed
- Signing via RSA
 - Exponentiate the hash of the message with a private key (RSA encryption with a private key)
- Signing via DSA
 - Defining Public Parameters (Primes, and Public Key)
 - Calculation of r and s

Questions

